

Lab: Stored DOM XSS

1. Mục đích của bài lab

→ Khai thác lỗ hổng Stored DOM XSS trong chức năng bình luận của website để thực thi hàm alert(1).

2. Trả lời câu hỏi

What defines Stored Cross-Site Scripting (XSS), and how does it differ from Reflected XSS and DOM-Based XSS?

→ Stored Cross-Site Scripting (Stored XSS) là một dạng lỗ hổng XSS mà mã JavaScript độc hại được kẻ tấn công chèn vào ứng dụng web và được lưu trữ trên máy chủ, chẳng hạn trong cơ sở dữ liệu, hệ thống bình luận hoặc hồ sơ người dùng. Mỗi khi người dùng truy cập trang chứa dữ liệu đó, trình duyệt sẽ tự động tải và thực thi đoạn mã độc. Khác với Stored XSS, Reflected XSS không lưu trữ payload trên máy chủ mà chỉ phản chiếu dữ liệu độc hại ngay trong phần hồi của một yêu cầu HTTP, thường yêu cầu nạn nhân nhấp vào một liên kết chứa mã độc. Trong khi đó, DOM-Based XSS xảy ra hoàn toàn ở phía trình duyệt khi JavaScript của trang web xử lý dữ liệu đầu vào không an toàn và chèn trực tiếp vào DOM, mà không cần máy chủ phản hồi nội dung chứa mã độc.

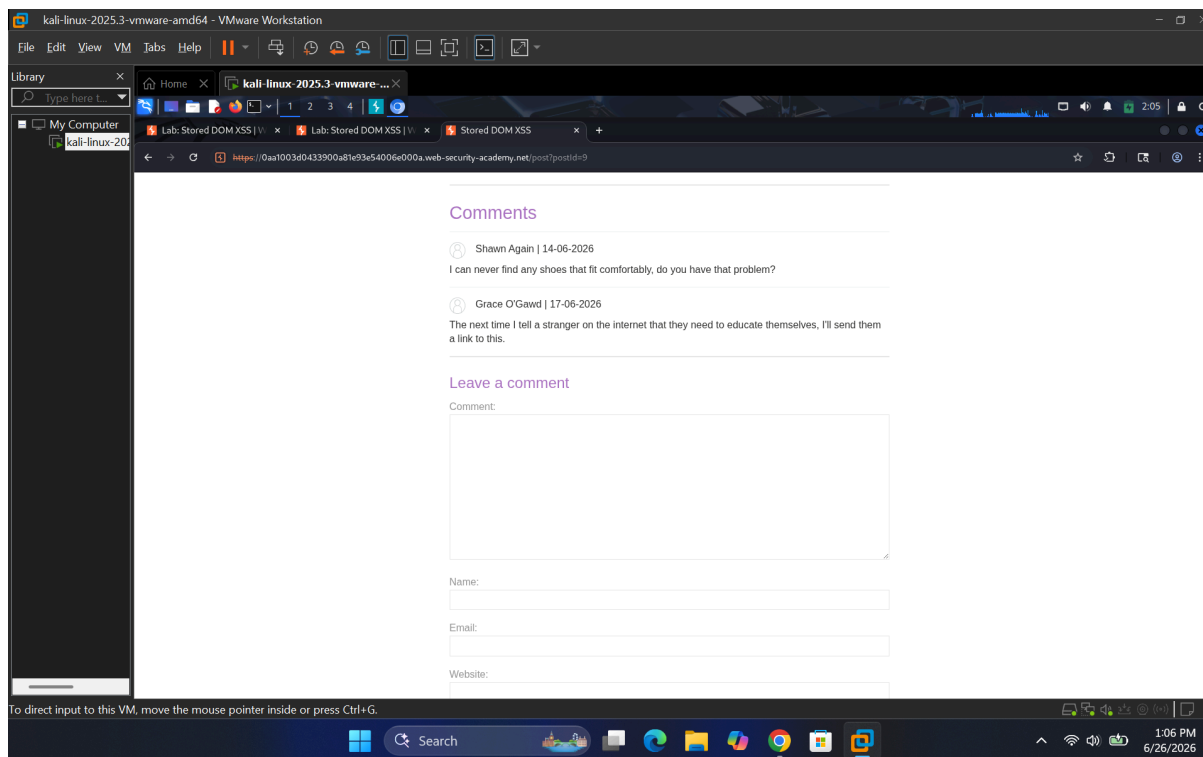
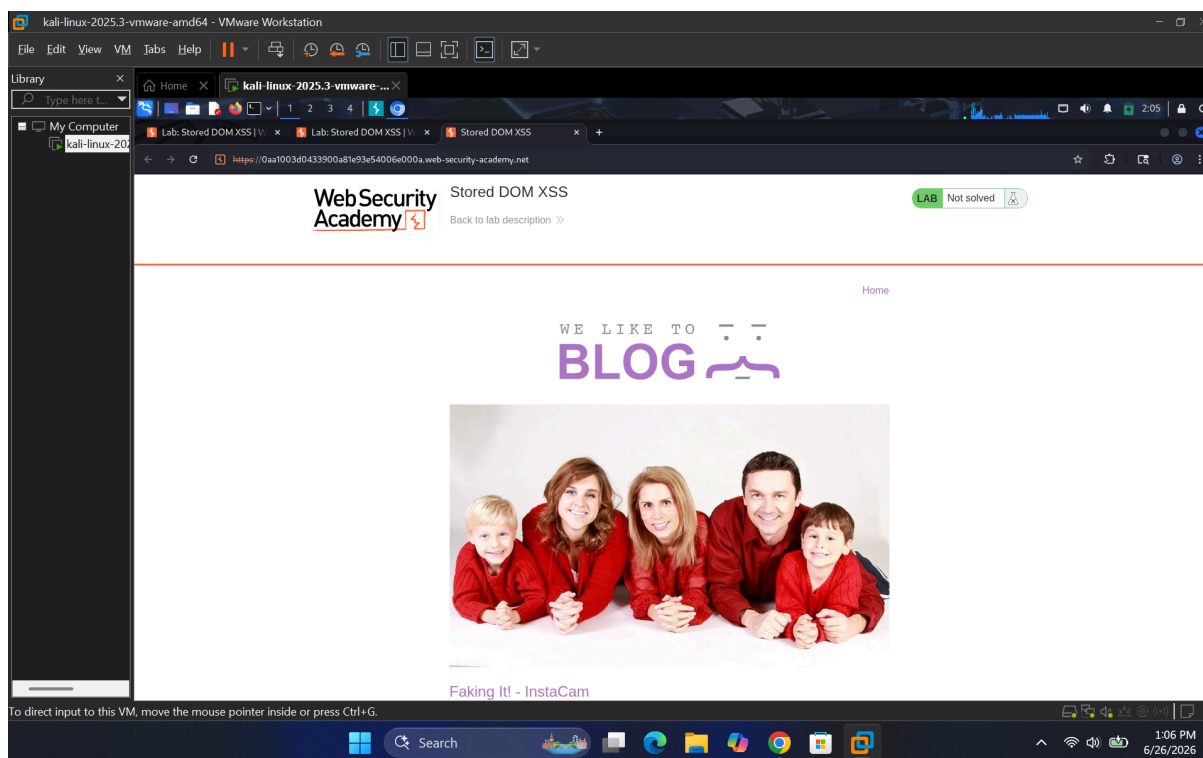
Explain the process of how malicious scripts are injected, stored, and subsequently executed in Stored XSS attacks, and discuss the potential consequences these attacks can have on both users and web applications.

→ Trong Stored XSS, kẻ tấn công đầu tiên chèn một đoạn mã JavaScript độc hại vào một trường nhập liệu của website như bình luận, bài đăng hoặc hồ sơ cá nhân. Nếu ứng dụng không kiểm tra hoặc mã hóa dữ liệu đầu vào đúng cách, đoạn mã này sẽ được lưu vào cơ sở dữ liệu của máy chủ. Khi người dùng khác truy cập trang chứa dữ liệu đã lưu, máy chủ gửi lại nội dung đó và trình duyệt sẽ thực thi mã JavaScript như một phần của trang web. Hậu quả của Stored XSS có thể rất nghiêm trọng, bao gồm đánh cắp cookie hoặc phiên đăng nhập, chiếm quyền tài khoản người dùng, thay đổi nội dung trang web, thực hiện các hành động trái phép dưới danh nghĩa nạn nhân, phát tán mã độc đến nhiều người dùng khác và gây ảnh hưởng đến uy tín cũng như tính bảo mật của ứng dụng web.

3. Chi tiết lab

B1. Truy cập bài viết

Mở lab và chọn một bài viết bất kỳ trên website. Cuộn xuống phần Leave a comment.

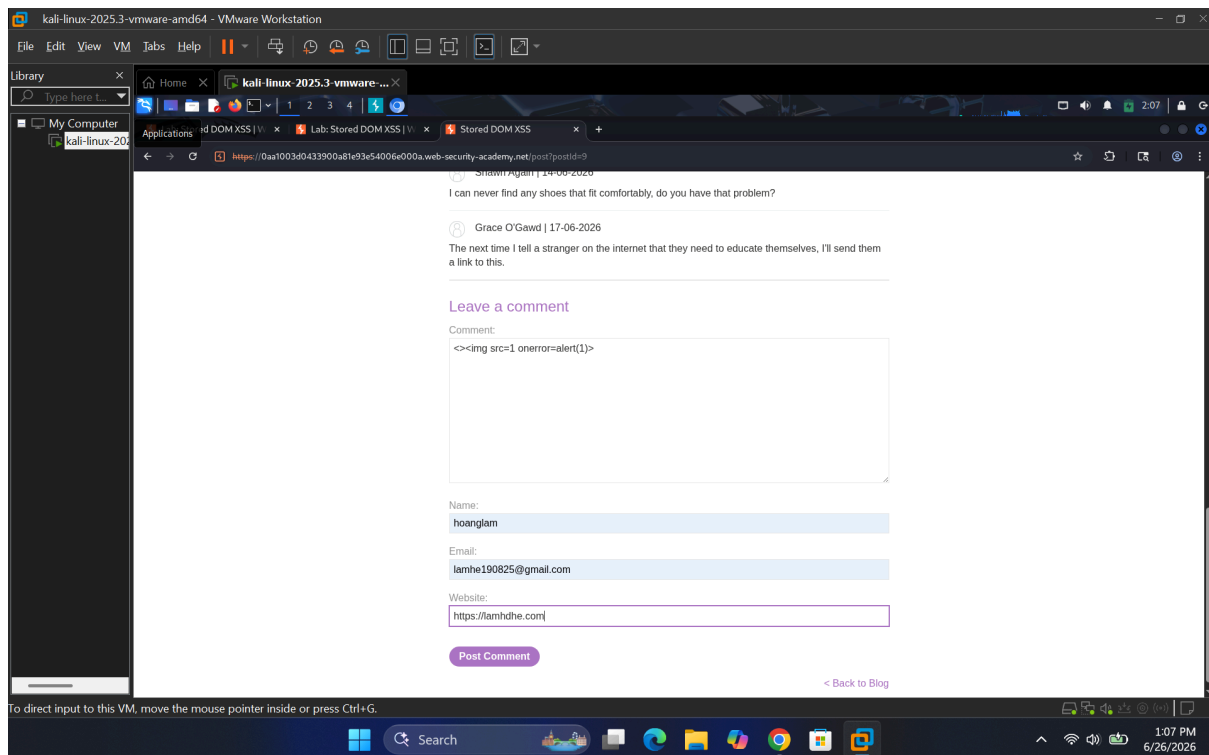


B2.Chèn payload

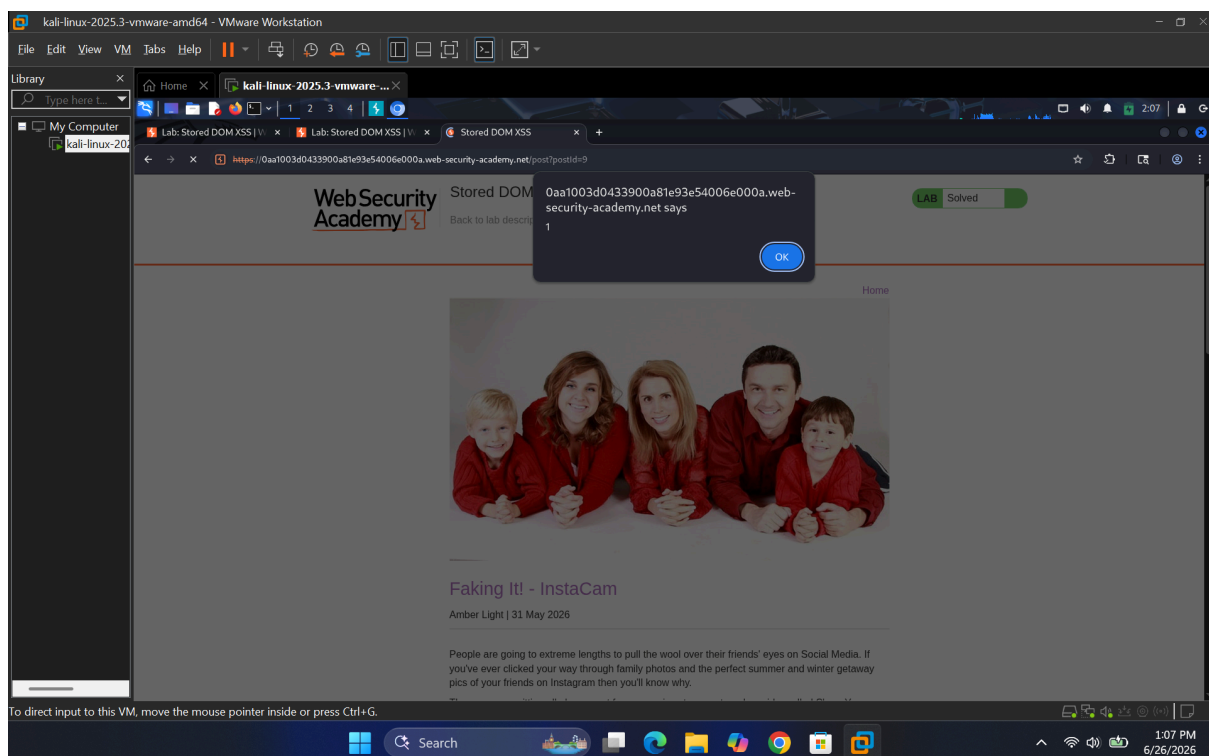
Nhập payload sau vào ô Comment:

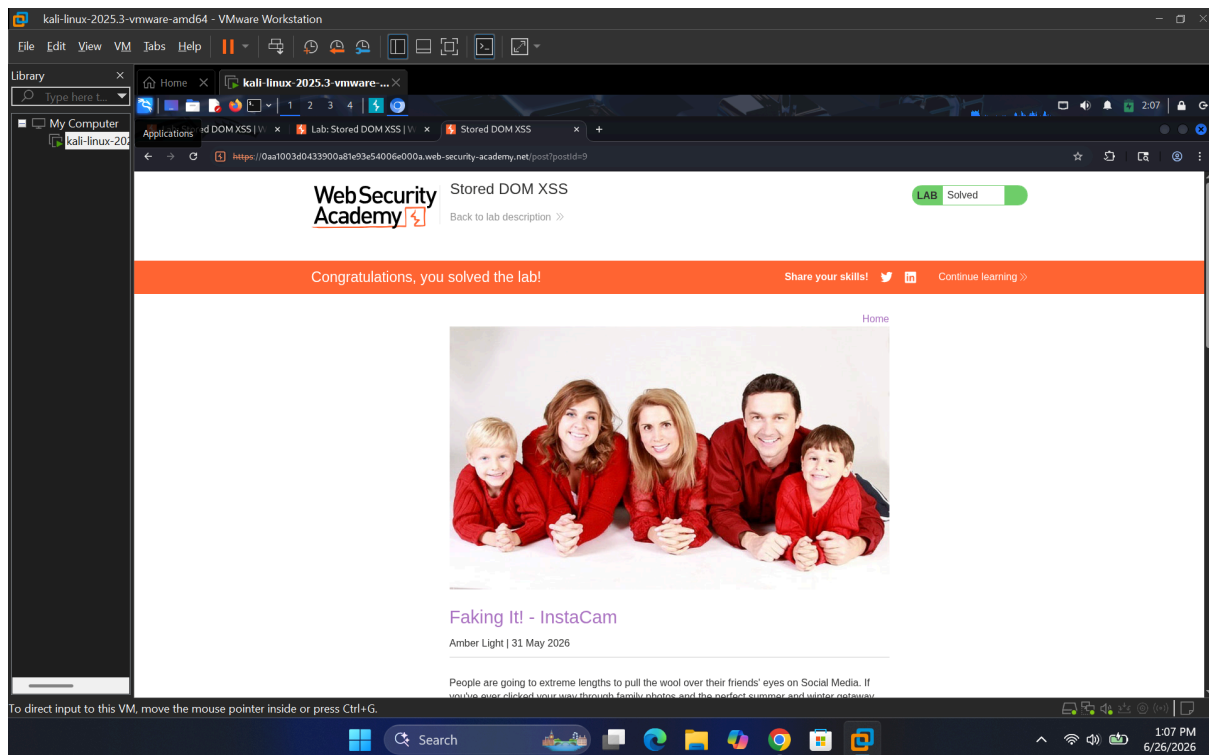
```
<><img src=1 onerror=alert(1)>
```

Điền các thông tin còn lại (Name, Email, Website) rồi nhấn Post Comment để gửi bình luận.



B3.Sau khi bình luận được lưu, tải lại trang hoặc mở lại bài viết. Trình duyệt hiển thị hộp thoại là 1, chứng tỏ mã JavaScript đã được thực thi thành công và lab được hoàn thành.





Phân tích payload:

`<><img src=1 onerror=alert(1)>`

- `<>`: Cặp dấu ngoặc được thêm vào để tiêu tốn lần thay thế đầu tiên của hàm `replace()`, giúp bypass cơ chế lọc.
- `<img>`: Thẻ HTML được dùng để thực thi mã JavaScript.
- `src=1`: Chỉ định nguồn ảnh không hợp lệ nên ảnh tải thất bại.
- `onerror`: Sự kiện được kích hoạt khi ảnh lỗi.
- `alert(1)`: Mã JavaScript được thực thi khi `onerror` xảy ra, chứng minh khai thác XSS thành công.